

AI INTAKE RISK ASSESSMENT CHECKLIST

Stakeholder Input Template | Complete all sections before governance sign-off

USE CASE NAME	What is this AI tool / feature / model called?	OWNER	Who is the named responsible owner? (Name / Title)
BUSINESS UNIT	Which team or department is sponsoring this?	MODEL TYPE	■ GenAI ■ Predictive ML ■ Rules + ML ■ Vendor Feature
DEPLOYMENT	■ Internal ■ Customer-facing ■ Public-facing	GO-LIVE TARGET	Target launch date
JURISDICTIONS	Countries / regions this will operate in	ASSESSMENT DATE	Date of this assessment

A) Risk Scoring | Score each driver 0–3: 0 = None / N/A · 1 = Low · 2 = Medium · 3 = High

Risk Driver	Score (0–3)	Notes / Evidence
1. Decision Impact <i>eligibility / pricing / hiring / claims / benefits</i>		
2. Autonomy <i>human-in-loop vs automated action</i>		
3. Data Sensitivity <i>PII / PHI / PCI / minors / biometrics</i>		
4. Security Exposure <i>integrations, tool use, write-access, data retrieval</i>		
5. Regulatory / Contract <i>privacy laws, sector rules, customer commitments</i>		
6. Bias / Discrimination <i>protected classes, disparate impact</i>		
7. Transparency Need <i>explainability, disclosures, contestability</i>		
8. Reliability Risk <i>hallucinations, accuracy, drift, edge cases</i>		
9. Vendor / Supply Chain <i>retention, training use, subcontractors, audit rights</i>		
10. Reputational Risk <i>brand exposure, harmful content</i>		
TOTAL SCORE	/ 30	

B) "Auto-High" Triggers — tick any that apply → any ☒ automatically sets tier to HIGH

- ☒ Automates or materially influences decisions about people (employment, credit, claims, pricing, eligibility)
- ☒ Uses regulated data (PHI / PCI) or sensitive personal data (biometrics / minors)
- ☒ Public-facing or customer-facing generative output
- ☒ Connects to internal systems with write access or broad data retrieval
- ☒ Vendor terms unclear on data retention / training or no audit / incident rights
- ☒ No logging / monitoring feasible (can't measure failures or usage)

C) Risk Tier Determination — tick the applicable tier

- ☒ **Low:** Total score 0–9 AND no Auto-High triggers
- ☒ **Medium:** Total score 10–19 AND no Auto-High triggers
- ☒ **High:** Total score 20–30 OR any Auto-High trigger checked

Required Approver(s) — tick all that apply:

☒ Compliance

☒ Security

☒ Legal / Privacy

☒ Risk / ERM

D) Required Artifacts by Tier — check off each item before launch

Tier 1 — LOW (required for all tiers)	
☒ Use Case Summary (purpose, users, workflow, boundaries)	
☒ Data Sheet (data types, sources, retention, access)	
☒ Vendor / Model Facts (who, where hosted, version)	
☒ Basic Security Review (access control, least privilege)	
☒ Evaluation Plan — Lite (basic accuracy / prompt tests for GenAI)	
☒ Monitoring Plan — Lite (usage logging + incident route)	
☒ Human Oversight Statement (who reviews outputs, when)	
Tier 2 — MEDIUM (adds to Low)	
☒ DPIA / Privacy Impact Assessment (or equivalent)	
☒ Threat Model — Lite (prompt injection, data leakage, abuse paths)	
☒ Model Card — Standard (intended use, limits, risks, training data summary)	
☒ Evaluation Plan — Standard (quality, bias checks, red-team prompts for GenAI)	
☒ Monitoring Plan — Standard (drift / hallucination tracking, alerts, review cadence)	
☒ Human-in-the-Loop Design (decision points, override, escalation)	
☒ Third-Party Risk Review (DPA, retention, subprocessors, incident notification, audit rights)	
Tier 3 — HIGH (adds to Medium)	

■ Formal Risk Assessment Memo (what can go wrong + mitigations + residual risk)	
■ Full Threat Model & Security Test Evidence (abuse testing, prompt injection defences, access controls)	
■ Bias / Fairness Assessment (if people-impacting) + mitigation plan	
■ Explainability & Notice Plan (disclosures, contestability / appeals if relevant)	
■ Robust Evaluation Report (benchmarks, failure modes, acceptance thresholds)	
■ Operational Readiness Plan (SOPs, incident runbook, rollback plan, model change control)	
■ Monitoring & Audit Evidence Plan (logs, retention, periodic review schedule)	
■ Legal Review Sign-off (contracts, regulatory obligations, customer commitments)	

E) Launch Decision

Decision: ■ Go ■ Conditional Go ■ No-Go

Conditions (if Conditional Go): _____

Next Review Date: _____

Reassessment Trigger(s): *model change / new data source / new geography / new feature or integration*

Assessed by: _____

Date: _____

Signature: _____